BÁO CÁO ĐỒ ÁN CHUYÊN NGÀNH HỌC KỲ II NĂM HỌC 2026 – 2027

Họ và tên: Lê Minh Nhật **MSSV: 2380601546**

Họ và tên: Nguyễn Minh Tuấn **MSSV: 2380602459**

Lớp: 23DTHB7 **Chuyên ngành: An Ninh Mạng** **Tuần số: 4**

Đề tài đăng ký: XÂY DỰNG HỆ THỐNG IAM DỰA TRÊN KEYCLOAK THEO ĐỊNH HƯỚNG ZERO TRUST

Nội dung báo cáo (các phần mà SV/nhóm đã tìm hiểu, trình bày chi tiết dưới đây).

1. Mục tiêu tuần 4

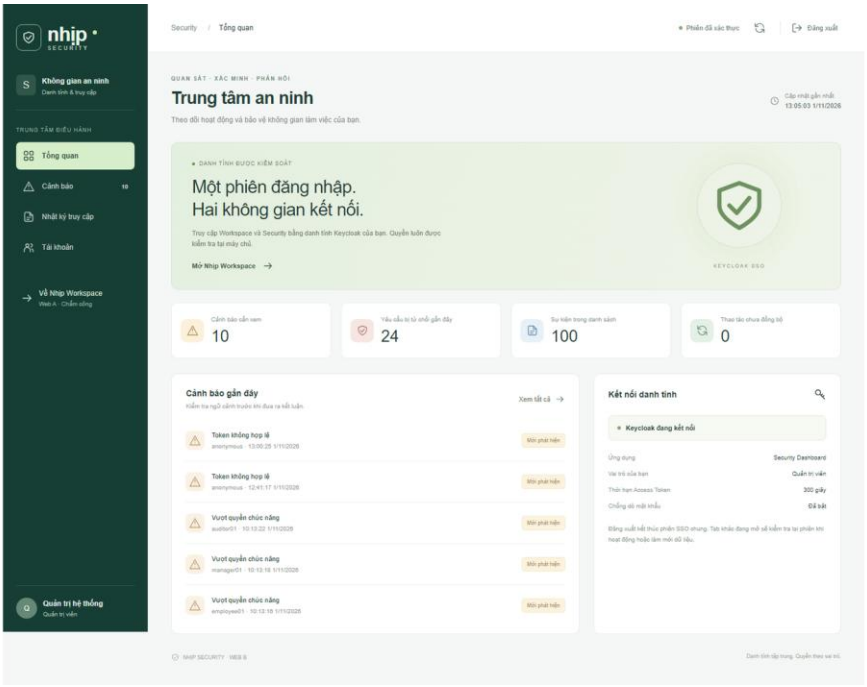
Kế thừa Web A và RBAC ở tuần 3, tuần 4 tập trung triển khai Giai đoạn 3 – Web B và SSO: xây dựng Security Dashboard độc lập; cấu hình OIDC Client security-dashboard, PKCE S256 và Audience security-api; kiểm thử đăng nhập một lần hai chiều giữa Web A và Web B. Đồng thời kiểm chứng phân quyền từng ứng dụng, đăng xuất liên ứng dụng và truy cập qua HTTPS trong mạng LAN/VPN.

2. Các công việc đã thực hiện

2.1. Xây dựng Web B – Security Dashboard

Xây dựng Web B độc lập trong thư mục web-b bằng React/Vite với giao diện Nhịp Security. Ứng dụng có trang tổng quan, cảnh báo, nhật ký và quản lý tài khoản theo vai trò, hỗ trợ máy tính và điện thoại. Web A tiếp tục phục vụ chấm công; hai ứng dụng có liên kết chuyển đổi và cùng sử dụng Keycloak để xác thực.

Kết quả: admin đăng nhập và sử dụng các chức năng Web B; auditor được đọc dữ liệu giám sát. Kiểm thử giao diện điện thoại xác nhận trang không bị tràn ngang.

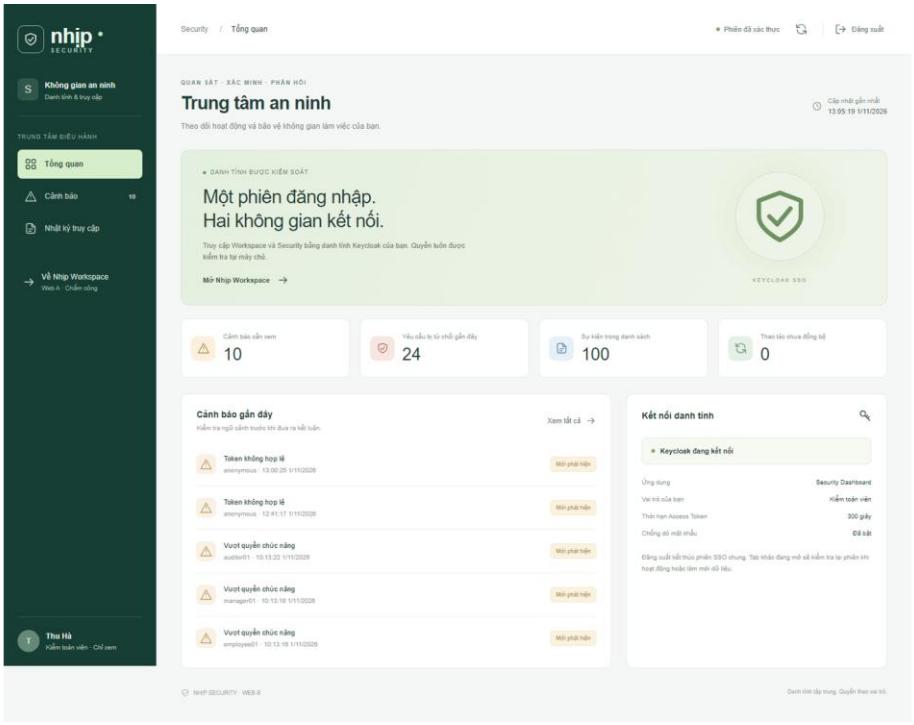


Hình 2.1. Giao diện Nhịp Security sau khi admin01 đăng nhập Web B.

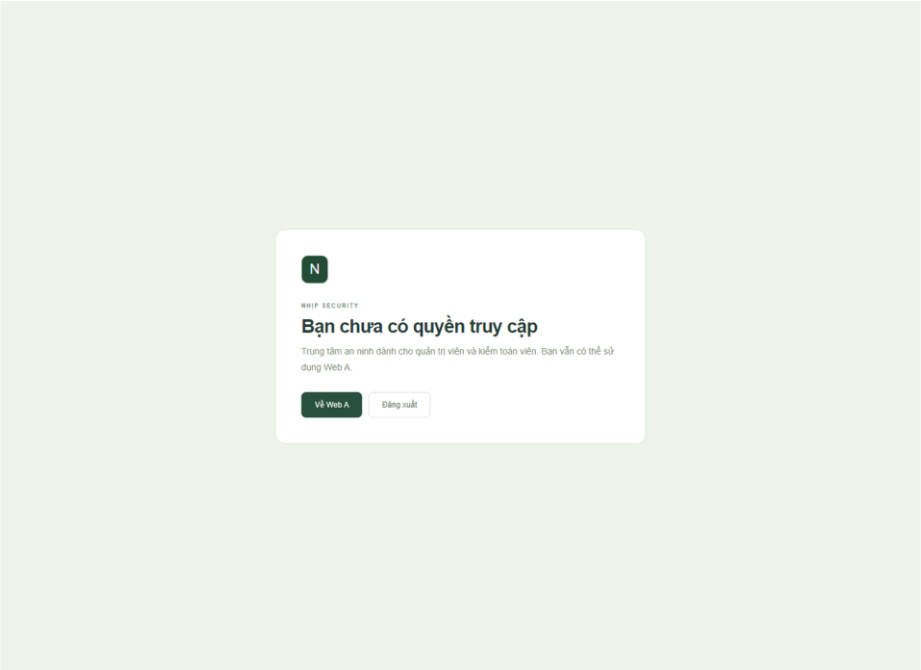
2.2. Cấu hình OIDC Client và phân quyền Web B

Tạo security-dashboard là public client, dùng Authorization Code Flow và PKCE S256, Audience security-api và scope basic để token có sub. Web A giữ employee-portal và employee-api. Backend xác minh chữ ký, issuer, thời hạn, azp, audience theo client, hồ sơ và vai trò; token Web B không được dùng để đọc nghiệp vụ chấm công.

Kết quả: admin và auditor được vào Web B; auditor bị từ chối API quản lý tài khoản. employee/manager bị chặn tại UI và API với HTTP 403 nhưng vẫn dùng được Web A theo quyền.



Hình 2.2. Auditor truy cập Web B với menu chỉ đọc, không có mục Tài khoản.

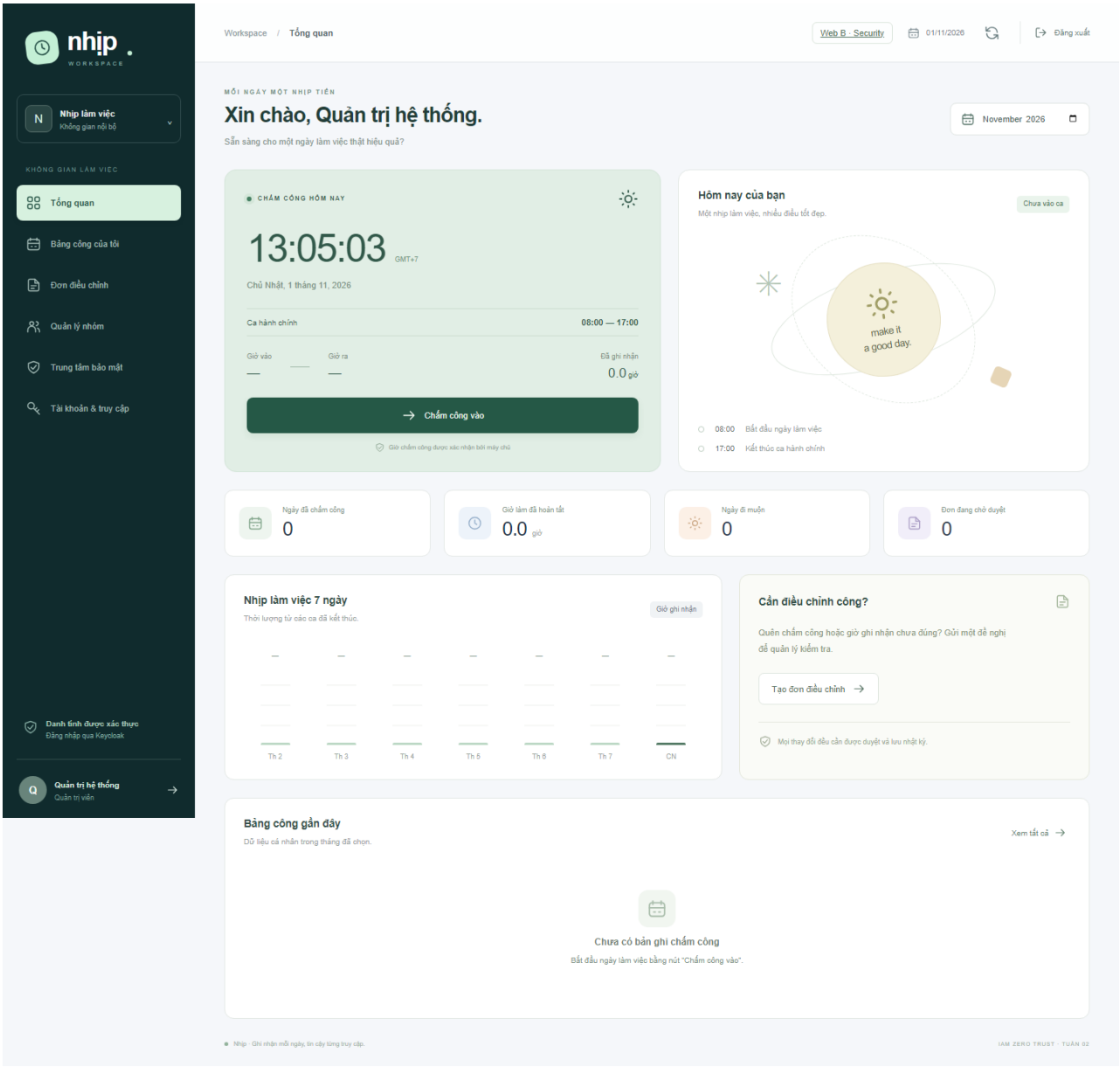


Hình 2.3. Web B từ chối tài khoản employee01 không đủ quyền truy cập.

2.3. Tích hợp và kiểm thử SSO hai chiều

Tích hợp keycloak-js vào Web B và dùng chung realm company-iam với Web A. Khi phiên Keycloak còn hiệu lực trong cùng hồ sơ trình duyệt, người dùng chuyển A → B hoặc B → A không phải nhập lại mật khẩu. Mỗi ứng dụng nhận token riêng theo client và giữ token trong bộ nhớ; không sao chép token giữa hai Web.

Kết quả: kiểm thử cả hai chiều đều không xuất hiện bước nhập lại mật khẩu; token có client và audience riêng nhưng cùng phiên Keycloak. Trình duyệt hoặc thiết bị khác phải đăng nhập độc lập.



Hình 2.4. Web A với admin01 trong lượt kiểm thử chuyển ứng dụng và SSO.

2.4. Kiểm soát đăng xuất và triển khai HTTPS LAN/VPN

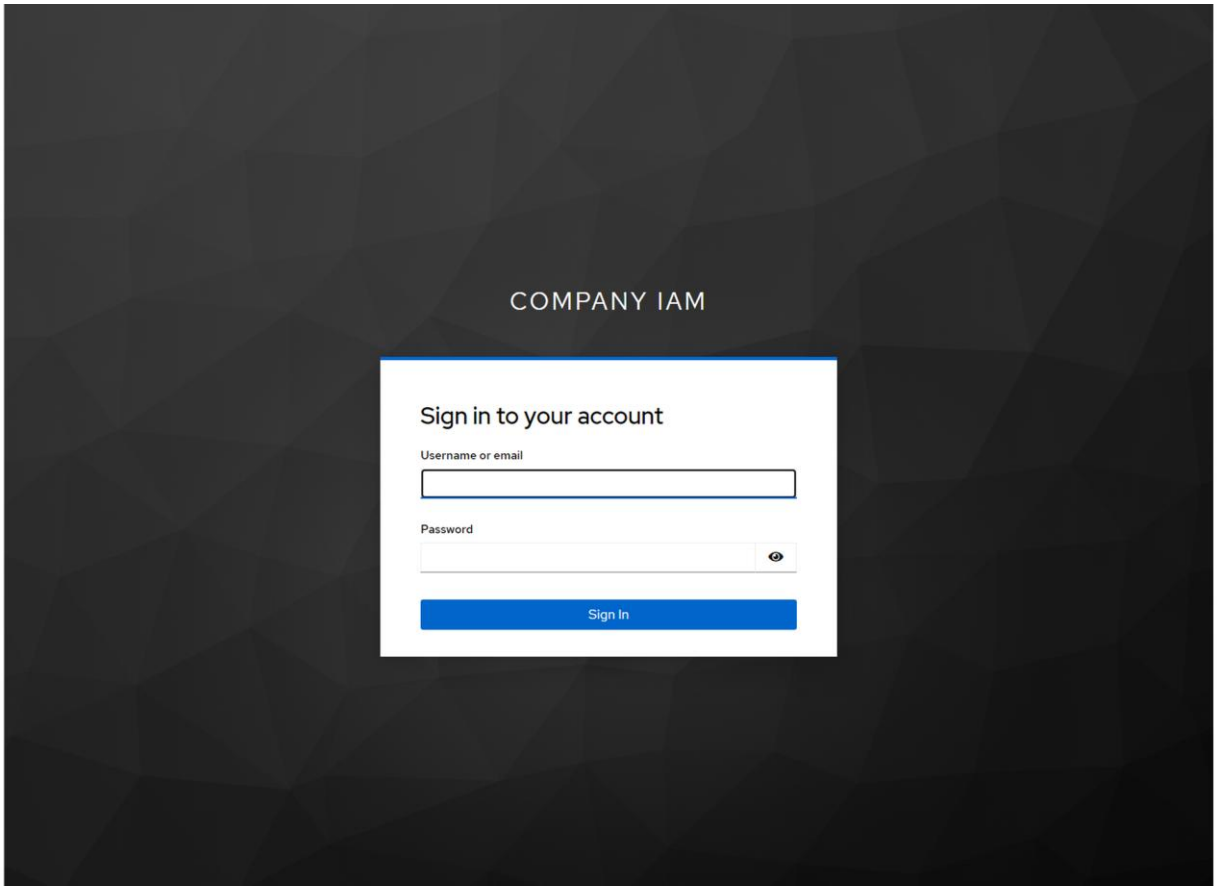
Backend đối chiếu sid trong token với phiên Keycloak thật, cache tối đa 5 giây; frontend kiểm tra phiên mỗi 15 giây và khi nhận focus. Khi đăng xuất một ứng dụng, ứng dụng còn lại phát hiện phiên kết thúc; API từ chối token cũ dù chưa hết hạn. Nếu không kết nối được Keycloak để kiểm tra phiên, API trả HTTP 503.

Triển khai HTTPS gateway cho Web A tại /a/, Web B tại /b/, API và endpoint xác thực qua một địa chỉ LAN/VPN. Backend kết nối Keycloak qua loopback; issuer khớp URL HTTPS công khai. Đã kiểm tra chuỗi chứng chỉ, IP SAN và chặn đường dẫn riêng tư; máy thứ hai truy cập được HTTPS nhưng chưa xác nhận tin cậy CA và đăng nhập.

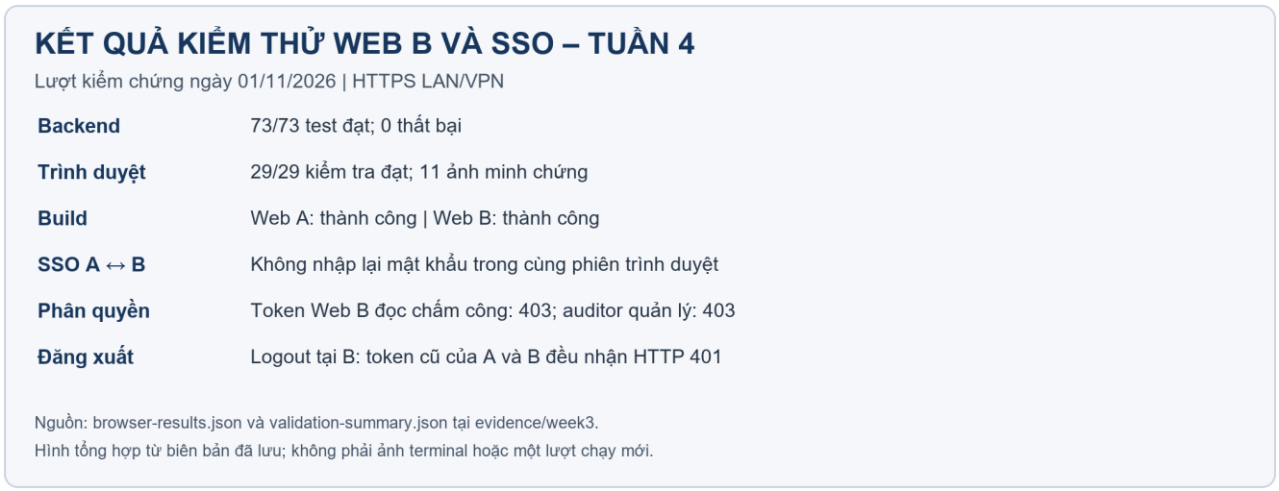
2.5. Kiểm thử SSO, phân quyền và đăng xuất

Lượt kiểm thử HTTPS LAN/VPN ngày 01/11/2026 hoàn tất lúc 13:05:37 (UTC+7), đạt 29/29 kiểm tra và lưu 11 ảnh. Các kịch bản gồm SSO A ↔ B, client/audience riêng, chặn token Web B đọc chấm công, giới hạn auditor, từ chối employee/manager và đăng xuất hai chiều. Sau khi logout tại B, token cũ của cả A/B đều nhận HTTP 401.

Theo validation-summary.json ngày 01/11/2026, bộ backend đạt 73/73 test và cả hai Web build thành công. Đây là bản tổng kết, không phải log TAP gốc; bộ backend dùng môi trường kiểm thử và mô phỏng Keycloak, còn 29 kiểm tra trình duyệt chạy với hệ thống thật. Trình duyệt tự động bỏ qua tin cậy chứng chỉ lab; chuỗi CA và SAN được kiểm tra riêng.



Hình 2.5. Web A trở về trang đăng nhập sau khi đăng xuất tại Web B.



Hình 2.6. Tổng hợp biên bản: 73/73 test backend và 29/29 kiểm tra trình duyệt.

3. Kết quả đạt được trong tuần 4

- Xây dựng Web B độc lập với tổng quan, cảnh báo, nhật ký và quản lý tài khoản theo quyền.
- Cấu hình security-dashboard, PKCE S256 và security-api; kiểm soát client/audience tại API.
- Kiểm chứng SSO hai chiều A ↔ B trong cùng trình duyệt, mỗi ứng dụng giữ token riêng.
- Kiểm chứng đăng xuất liên ứng dụng và chặn token cũ; bổ sung HTTPS gateway cho LAN/VPN.
- Ghi nhận 73/73 test backend, 29/29 kiểm tra trình duyệt và build Web A/B thành công.

4. Hạn chế và công việc tiếp theo

Hệ thống là lab nội bộ; Keycloak còn dùng start-dev sau HTTPS proxy. SSO áp dụng trong cùng hồ sơ trình duyệt; tab nền bị đình chỉ có thể cập nhật logout chậm, API vẫn kiểm tra phiên khi có yêu cầu. Chưa triển khai Web B trên máy chủ thứ hai độc lập; chưa xác nhận bước tin cậy CA và đăng nhập trên thiết bị thứ hai.

Tuần 5 dự kiến tập trung MFA và tăng cường bảo mật: hoàn thiện đăng ký TOTP, kiểm thử mật khẩu kết hợp OTP và các trường hợp OTP sai, thiếu, hết hạn; kiểm tra vòng đời token/refresh token, Redirect URI, CORS và HTTPS. Hiện mới hỗ trợ yêu cầu CONFIGURE_TOTP theo tài khoản; chưa hoàn tất MFA OTP toàn hệ thống.

Minh chứng: Hình 2.1–2.5 lấy từ lượt kiểm thử HTTPS ngày 01/11/2026 tại evidence/week3 (tên thư mục lịch sử của giai đoạn 3, tương ứng tuần 4). Hình 2.6 trình bày lại browser-results.json và validation-summary.json, không phải ảnh terminal. Ảnh sử dụng và bản sao hai biên bản lưu tại word/minh_chung/tuan4; nội dung báo cáo đối chiếu tuan4.md và tiendo.md.